· You can identify threats and assess risk.
· Security mechanisms can be used to achieve your security goals, including authentication, access control, audit logging, and rate-limiting.

ANSWERS TO EXERCISES

1. c, e, and f. While other aspects of security may be relevant to different APIs, these three disciplines are the bedrock of API security.
2. d - An API Gateway is a specialized type of reverse proxy.
3. Confidentiality, Integrity, and Availability.
4. b - Data flows that cross trust boundaries are the most likely place for threats to occur. APIs often exist at trust boundaries.
5. Repudiation. By disabling audit logging the rogue system administrator will later be able to deny performing actions on the system as there will be no record.
6. e - Rate limiting primarily protects against denial of service attacks by preventing a single attacker from overloading the API with requests.
7. This is an example of capability-based access control. While the user logs in to Dropbox to use the UI, the URL on its own provides access to the file even if the user subsequently logs off. Typically, these URLs are only valid for a short period of time.
8. A hardware security is something you have. They are usually small devices that can be plugged into a USB